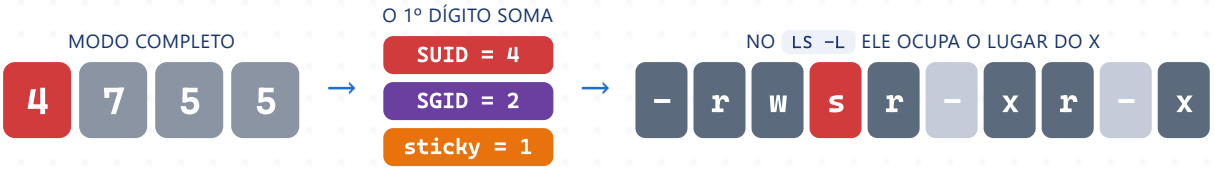
GUIA VISUAL 023

SUID, SGID E STICKY BIT

Você não lê `/etc/shadow` — mas troca sua senha. O `s` do `passwd` explica tudo.

023
GUIAS LINUX

O QUARTO DÍGITO OCTAL, O QUE QUASE NINGUÉM ESCREVE



OS TRÊS BITS, UM A UM

SUID (4) — EM EXECUTÁVEL

O processo ganha o **UID efetivo do dono do arquivo**. O UID **real** continua o seu (para log e sinais); é o **efetivo** que o kernel checa. Por isso `passwd` (dono root) grava no `shadow`.

SGID (2) — EM DIRETÓRIO

Todo arquivo criado ali **herda o grupo do diretório** em vez do grupo primário do autor — e subdiretórios herdam o próprio bit. É a pasta de equipe: `chgrp projeto` + `chmod 2775` + `umask 002`.

STICKY (1) — EM DIRETÓRIO

Com `w` num diretório qualquer um apaga arquivo alheio. O sticky restringe: **só o dono do arquivo** (ou do diretório, ou root) remove. É o `t` de `/tmp` — `1777`, `drwxrwxrwt`.

NA PRÁTICA

NO LS -L	BIT	COMO LER
`s` no dono	SUID	Minúscula = o `x` também está aceso. Roda como o dono.
`S` no dono	SUID	Maiúscula = bit ligado **sem** `x`. Quase sempre um `chmod` incompleto.
`s` no grupo	SGID	Executável roda com o grupo do arquivo; diretório impõe o grupo dele.
`t` em outros	sticky	Só o dono apaga. Em arquivo, hoje o Linux ignora (herança do Unix antigo).

SUID é a maior fonte de escalada de privilégio local. Nunca dê `chmod u+s` a um binário seu para fugir do `sudo`: você passa a garantir que ele é seguro contra *qualquer* entrada. Em **script o SUID é ignorado** pelo kernel (janela de corrida no shebang) — para privilégio pontual use regra restrita de `sudo` ou *capabilities*.

RESUMO RÁPIDO

- ✓ Quarto dígito: **4** SUID · **2** SGID · **1** sticky.
- ✓ SUID = UID **efetivo** do dono; o real segue sendo o seu.
- ✓ SGID em diretório = herança de grupo, propagada aos subdiretórios.
- ✓ Sticky (`1777`) = só o dono apaga — é o que protege `/tmp` .
- ✓ `S` / `T` maiúsculo = especial ligado sem `x` : revise o `chmod` .

NO KALI

Guarde uma **linha de base** logo após instalar: `find / -xdev -perm -4000 -type f 2>/dev/null | sort` . Um SUID que apareceu sozinho depois é dos sinais mais claros de comprometimento. Do lado ofensivo, essa mesma varredura (LinPEAS, GTFOBins) é o 1º passo da escalada local em alvo **autorizado** — `pkexec` já teve falhas graves, mantenha o `polkit` atualizado. Sem escopo escrito, é crime (Lei 12.737/2012).